

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
1	Input Validation Failure	OWASP Input Validation / OWASP A03	Penerapan Whitelist Validation	Diterapkan	Whitelist validation adalah aturan validasi yang hanya mengizinkan format data tertentu. Untuk JSON, backend perlu membatasi tipe data, panjang teks, slug, URL, email, tanggal, dan image path sebelum data disimpan.
2	XSS / Cross Site Scripting	OWASP XSS Prevention / OWASP A03	Penerapan Output Escaping dan Sanitasi Konten	Diterapkan	Konten dari JSON harus ditampilkan sebagai teks aman dan tidak boleh dirender sebagai HTML mentah. URL seperti javascript:, event HTML, script, iframe asing, dan rich text harus diblokir atau disanitasi.
3	Session Hijacking	OWASP Session Management / OWASP A07	Penerapan Cookie HttpOnly dan Secure Session	Diterapkan	Admin key yang berada di browser storage lebih mudah dicuri jika terjadi XSS. Session admin sebaiknya memakai cookie HttpOnly, Secure, SameSite, memiliki masa berlaku, dan hanya dikirim melalui HTTPS.
4	Client-side Data Exposure	OWASP Sensitive Data Exposure / OWASP A02 /CWE 200	Penerapan Server-side Secret Management	Diterapkan	Secret seperti admin password, SMTP password, API key, dan token hosting tidak boleh disimpan di JSON atau frontend bundle. Secret harus disimpan di environment server dan tidak memakai prefix NEXT_PUBLIC.
5	CSP Misconfiguration	OWASP CSP Security / OWASP CSP Cheat Sheet	Penerapan Content Security Policy	Diterapkan	CSP membatasi sumber script, image, iframe, dan koneksi API yang boleh dijalankan browser. Ini mengurangi dampak jika ada XSS atau resource asing yang tidak dipercaya.
6	HTTPS Weakness	OWASP Transport Layer Protection / OWASP A02 / OWASP Cryptographic Failure	Penerapan HTTPS dan Redirect HTTP	Akan diterapkan	HTTPS wajib digunakan di production agar admin login, API request, upload, dan contact form tidak bisa disadap. HTTP perlu diarahkan otomatis ke HTTPS.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemaan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
7	Plugin Frontend Vulnerability	OWASP Depedency Management / OWASP A06	Tidak menggunakan kontrol plugin frontend CMS	Tidak diterapkan	Poin ini tidak applicable karena project bukan CMS plugin-based. Sebagai pengganti, yang perlu dilakukan adalah audit dependency frontend yang benar-benar digunakan seperti Next.js, React, dan library npm.
8	Vulnerable Theme	OWASP Depedency Management / OWASP A06	Tidak menggunakan kontrol theme CMS	Tidak diterapkan	Project menggunakan komponen custom Next.js, bukan theme CMS seperti WordPress. Karena attack surface theme CMS tidak ada, poin ini tidak dihitung sebagai kelemahan.
9	Outdated Frontend Assets	OWASP Depedency Management / A06	Penerapan Dependency Audit dan Update Policy	Diterapkan	Library frontend seperti Next.js, React, Swiper, Framer Motion, dan lucide perlu diaudit berkala. Jalankan npm audit, review changelog, update package rentan, dan jaga lockfile.
10	Fake Login Interface	NIST SP 800-63B	Penerapan Verifikasi Domain Admin	Diterapkan	Halaman /admin bisa dipalsukan untuk phishing. Admin harus hanya login dari domain resmi dengan HTTPS, dan tidak memasukkan password dari link email/chat yang mencurigakan.
11	Secure Login Weakness	NIST SP 800-63B	Penerapan Strong Admin Authentication	Diterapkan	Login admin harus memakai password kuat dari environment variable, tanpa default password. Tambahkan rate limit, lockout sementara, dan 2FA jika admin panel dipakai production.
12	SQL Injection	OWASP Injection A03 / cwe 89	Penerapan JSON Schema Validation dan Content Sanitization	Diterapkan	SQL Injection tidak relevan karena tidak ada database/query SQL. Risiko penggantinya pada JSON adalah JSON/Data Structure Injection, yaitu input yang merusak struktur JSON atau menyisipkan field/payload berbahaya. Diperlukan JSON Schema Validation, whitelist field, validasi tipe data, panjang input, slug, URL, image path, dan sanitasi konten sebelum disimpan.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
13	API Security Failure	OWASP API Top 10	Penerapan API Authentication dan Rate Limiting	Diterapkan	Endpoint /api/content, /api/upload, dan /api/contact tetap terlihat dari browser. Backend harus mengecek auth, method, ukuran request, validasi body, dan jumlah request berulang.
14	Broken Access Control	OWASP A01	Penerapan Access Control pada Endpoint Admin	Diterapkan	Endpoint admin hanya boleh digunakan oleh admin. Perlu cek auth di setiap endpoint, allowlist nama file JSON, cegah path traversal, dan role permission jika admin lebih dari satu.
15	Authentication Failure	OWASP A07	Penerapan Penghapusan Default Password	Diterapkan	Fallback password seperti ami-admin-2026 harus dihapus. Jika ADMIN_PASSWORD kosong di production, API harus menolak request agar tidak memakai password default.
16	JWT / Token Abuse	OWASP API Security / OWASP JWT	Penerapan Token Expiration atau Server Session	Diterapkan	Walaupun belum memakai JWT, admin key statis memiliki risiko serupa token tanpa masa berlaku. Gunakan expiry atau pindahkan ke session cookie server-side.
17	File Permission Misconfiguration	OWASP A05 / OWASP ASVS	Penerapan Permission File dan Folder Minimal	Akan diterapkan	Pada cPanel/VPS, file JSON dan upload harus memakai permission minimal. Umumnya folder 755, file JSON 644, env/config 600 jika memungkinkan, dan jangan memakai 777.
18	File Upload Exploit	OWASP Security Misconfiguration / OWASP A04 / OWASP A05	Penerapan Upload File Validation	Diterapkan	Upload harus dibatasi ke tipe gambar aman, dicek magic bytes, diberi nama acak, dibatasi ukuran, tidak menerima SVG/executable, dan folder upload tidak boleh mengeksekusi script.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemaanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
19	Security Misconfiguration	OWASP A05	Penerapan Hardening Environment dan Config	Diterapkan	Konfigurasi production harus menghapus default password, menyimpan secret di environment hosting, mematikan debug mode, membatasi CORS jika diperlukan, dan tidak expose backup/config.
20	Logging & Monitoring Failure	OWASP A09 Login , monitoring Failure	Penerapan Audit Log Admin dan API	Diterapkan	Aktivitas penting seperti login gagal, update JSON, upload file, error API, dan contact abuse perlu dicatat di log private agar insiden dapat ditelusuri.
21	Plugin Vulnerability Backend	OWASP A06 / OWASP Depedency Management	Tidak menggunakan kontrol plugin backend CMS	Tidak diterapkan	Project bukan CMS dengan plugin backend. Poin ini tidak dihitung sebagai celah; penggantinya adalah audit dependency backend seperti Next.js dan nodemailer.
22	CMS Core Exploit	OWASP A06 / OWASP Depedency Management	Tidak menggunakan kontrol CMS Core	Tidak diterapkan	Project bukan WordPress/Joomla/CMS core. Risiko CMS core tidak ada, sehingga kontrol yang relevan adalah update framework Next.js dan dependency npm.
23	Admin Panel Attack	NIST SP 800-63B / OWASP ASVS	Penerapan Proteksi Brute Force Admin	Diterapkan	Halaman /admin perlu dilindungi dari brute force. Terapkan password kuat, rate limit, lockout sementara, HTTPS, dan optional IP allowlist atau 2FA.
24	Database Exposure	OWASP A02 / CWE 200	Penerapan Private JSON storage dan File access control	Diterapkan	Project ini tidak memakai database tetapi memakai JSON, maka. Risiko penggantinya adalah JSON File Exposure, yaitu file JSON, backup, atau config terbuka publik. Pastikan JSON tidak berada di folder public, backup disimpan private, permission file aman, dan secret tidak disimpan di JSON.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
25	Remote Code Execution / Plugin Upload	OWASP File Upload /CWE-434 / CWE-94	Penerapan Larangan Upload File Executable	Diterapkan	Walaupun project hanya upload gambar, endpoint upload tetap harus menolak PHP, JS, HTML, SVG bebas, dan file executable agar tidak bisa menjalankan kode di server.
26	Backup Exposure	OWASP ASVS / CWE 200	Penerapan Private Backup Storage	Akan diterapkan	Backup JSON, source zip, atau file konfigurasi tidak boleh ditempatkan di public_html/public. Backup harus disimpan di lokasi private, dibatasi permission, dan dihapus jika tidak perlu.
27	Malware Persistence	OWASP File Upload	Penerapan Monitoring File dan Upload Hardening	Akan diterapkan	Pada shared hosting/VPS, malware bisa bertahan jika folder writable tidak dikontrol. Batasi permission, hardening upload, dan lakukan monitoring atau scan file hosting.
28	Third-Party Resource Governance	OWASP Cheat Sheet / ASVS	Penerapan Inventory Resource Eksternal	Diterapkan	Resource seperti Google Maps, CDN, font, dan widget perlu diinventarisasi. Batasi domain melalui CSP dan hindari script pihak ketiga yang tidak jelas.
29	Privacy and Data Minimization	NIST Privacy Framework	Penerapan Minimalisasi Data Contact Form	Tidak diterapkan	Contact form hanya boleh meminta data yang dibutuhkan seperti nama, email, company/phone jika perlu, dan message. Jangan simpan data pribadi di browser storage.
30	Tracking and Consent Control	NIST Privacy Framework	Tidak menggunakan kontrol tracking aktif	Tidak diterapkan	Jika website belum memakai analytics/cookie tracking, poin ini tidak dihitung sebagai celah. Jika tracking ditambahkan, perlu cookie notice, consent, dan inventory tracker.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
31	External Link Safety	OWASP HTML5 / Reverse Tabnabbing	Penerapan rel noopener noreferrer	Diterapkan	Link eksternal dengan target blank perlu memakai rel="noopener noreferrer" agar halaman asal tidak bisa dimanipulasi melalui window.opener. Project sudah banyak menerapkan pola ini.
32	Data Retention Enforcement	NIST Privacy Framework	Tidak menggunakan penyimpanan submission database	Tidak diterapkan	Contact form saat ini dikirim melalui email dan tidak disimpan sebagai database submission. Jika nanti disimpan, perlu created_at, retention policy, dan penghapusan data lama.
33	Contact Form Abuse Control	OWASP ASVS / OWASP Automated Threats	Penerapan Rate Limit Contact Form	Tidak diterapkan	Endpoint /api/contact perlu dilindungi dari spam dan email bombing dengan rate limit, cooldown, panjang pesan maksimum, captcha jika perlu, dan logging percobaan berulang.
34	Email Header and Body Injection Control	OWASP XSS Prevention / CWE 93	Penerapan Email Input Escaping	Diterapkan	Input user yang masuk ke email perlu dibatasi dan di-escape. Validasi replyTo, batasi subject/body, dan cegah CRLF atau manipulasi header email.
35	Resource Exhaustion Protection	OWASP API Security / OWASP API4 Resource Consumption	Penerapan Request Size Limit dan Throttling	Akan diterapkan	API bisa terbebani oleh request besar atau berulang. Batasi body request, upload size, timeout, dan rate limit agar server tetap stabil.
36	Dependency Upgrade Validation	NIST SSDF SP 800 218 / OWASP Automated Threat	Penerapan Validasi Upgrade Dependency	Akan diterapkan	Sebelum update dependency, lakukan npm audit, cek changelog, jalankan build/lint/test, dan pastikan package-lock tetap konsisten.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemaan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
37	Admin Workflow Safety	OWASP Transaction Authorization / OWASP SAMM	Penerapan Preview dan Confirm Action	Diterapkan	Admin perlu melihat preview sebelum save dan mendapat konfirmasi untuk aksi sensitif seperti delete agar salah edit atau salah hapus dapat dicegah.
38	Content Change Visibility	OWASP Transaction Authorization	Penerapan Ringkasan Perubahan Konten	Akan diterapkan	Sebelum menyimpan JSON, tampilkan diff atau ringkasan field yang berubah agar admin bisa mendeteksi perubahan salah atau tidak sah.
39	Admin Input Type Enforcement	OWASP Input Validation	Penerapan Input Sesuai Tipe Data	Diterapkan	Field admin tidak boleh semuanya teks bebas. Gunakan URL input, date picker, select kategori, number constraint, boolean toggle, dan image picker sesuai tipe field.
40	Admin Preview Isolation	OWASP HTML5 Security / OWASP CSP	Penerapan Isolasi Preview Konten	Akan diterapkan	Preview gambar/rich content harus hanya menampilkan konten aman. Jika ada HTML/iframe preview, gunakan sandbox atau whitelist format yang diizinkan.
41	Content Approval Control	OWASP Authorization	Penerapan Draft Review Publish	Akan diterapkan	Jika nanti ada banyak admin/editor, perubahan konten sebaiknya tidak langsung publish. Gunakan status draft, review, dan published dengan endpoint publish khusus.
42	Revision History and Rollback	NIST SSDF SP 800 218 / OWASP Logging	Penerapan Backup JSON Sebelum Overwrite	Diterapkan	Sebelum JSON ditimpa, simpan versi lama dengan timestamp agar konten dapat di-rollback jika salah edit, file rusak, atau terjadi deface.
43	Role-Based Publishing Permission	OWASP Authorization / OWASP A01	Penerapan Role dan Permission Admin	Akan diterapkan	Jika admin lebih dari satu, buat permission untuk create, edit, delete, publish, rollback, upload, dan update setting. Validasi permission harus dilakukan di backend.

Tabel di bawah ini adalah checklist kemaanan serta penerapan standar kemanan OWASP & NIST untuk sistem Website

Standard Keamanan			Penerapan Keamanan di Website JSON		
No	Poin Checklist Keamanan	Standar Acuan	Hasil	Penerapan	
	Kesimpulan				
	Total Checklist PDF		43		
	Relevan untuk JSON (dihitung)		35		
	Sudah diterapkan		25		
	Akan diterapkan		10		
	Tidak diterapkan / N/A		8		
	Score implementasi saat ini		81,40%		Poin N/A tidak dihitung sebagai tidak aman karena attack surface-nya tidak ada pada arsitektur JSON.

NOTE

NOTE

NOTE

Hanya ada role admin saja yang dapat akses cms,
jadi tidak perlu di berikan RBAC (Role Base Access
control)

Tidak menggunakan JWT Library, namun secara
teknik pengamana sudah diterapkan identik dengan
mekanisme JWT dengan (Signed Payload and
Expiration), lebih spesifik dengan mekanisme
HMAC-SHA256

Sudah di terapkan 40% nya dengan pembuatan file
file pendukung untuk config file permission nanti
saat config di VPS. Sisa progress nya akan di
selesaikan saat config di hosting VPS

Sudah di tambahkan mekanisme validasi dengan
Magic bytes, yaitu untuk mendeteksi payload yang
di masukkan, agar isinya sesuai, contoh payload
expected JPG/JPEG, maka jika diisi PHP akan auto
reject, log akan muncul error kode 415

NOTE

NOTE: ketika deploy, re check mode production aktif, serta debug mode off ketika sudah masuk tahapan deployment, bisa di cek dari file next.config.mjs, namun saat ini sudah di set agar otomatis kerubah ke production ketika sudah deploy

Sudah diterapkan langsung, dengan membuat mekanisme Log Activity yang auto detecting semua aktivitas dari sisi cms dengan mendeteksi Request, lalu log tersebut akan di simpan dalam folder /Logs dalam sourcecode

NOTE

sudah sepenuhnya diterapkan dengan beberapa layer, yaitu 1 MIME type check, 2 Magic bytes validation, 3 Random File naming, 4 NGINX Execution block (walaupun file .exe terupload, tidak akan di eksekusi dengan layer ke 4 ini)

Note: Sudah Hampir terpenuhi semua, tahapan finalisasi akan di terapkan saat config hosting VPS, dengan mengatur File permission nya, dengan dokumentasi yang sudah di siapkan

Hampir terpenuhi, namun tetap ada yang harus di terapkan saat config VPS, untuk melakukan instalasi AV. dapat menggunakan Opensource AV seperti Clam AV untuk penangkal Malware nantinya.

sudah di buatkan file inventarisya di dalam folder lib, yaitu adalah file externalRerource.js, serta sudah ditambahkan catatan ke [security.md](#) sebagai dokumentasi

NOTE

Sudah terimplementasi dengan menggunakan beberapa function spt escape HTML, normalizeheadervalue, dan is valid email, yang ditujukan untuk menghindari adanya serangan html body injection, hingga manipulasi email header.

NOTE

NOTE